

---

# UbuntuOS Web

## Codebase Audit Report

---

Consolidated Severity-Ranked Findings from Multi-Phase Audit  
Evidence-Grounded Review: Documentation vs. Source Code

Audit Date: 2026-06-02  
Security Audit Baseline: 2026-05-31  
Codebase Snapshot: codebase\_fileset\_bundle.md

| Audit Summary          |   |                                                          |
|------------------------|---|----------------------------------------------------------|
| Critical Issues        | 0 | No active exploitable vulnerabilities found              |
| High-Severity Issues   | 2 | 17+ unvalidated localStorage reads; ~587 KB dead import  |
| Medium-Severity Issues | 8 | Doc-code discrepancies, test gaps, convention violations |
| Low-Severity Issues    | 5 | Dead code, cosmetic issues, minor optimizations          |
| Informational          | 6 | Confirmed positives, validated security fixes            |

# Table of Contents

---

- 1. Project Overview and Architecture
- 2. Phase 1: Document-by-Document Deep Extraction
- 3. Phase 2: Cross-Document Reconciliation
- 4. Phase 3: Source Code Validation
- 5. Phase 4: Multi-Dimensional Critical Audit
- 6. Phase 5: Consolidated Severity-Ranked Findings
- 7. Improvement Recommendations

# 1. Project Overview and Architecture

UbuntuOS Web is a comprehensive, high-fidelity web-based replica of the Ubuntu Linux desktop environment, built as a Single Page Application (SPA) that runs entirely in the browser. The project features a custom window manager, a virtual file system with localStorage persistence, and 54 interactive applications spanning seven categories: System (7), Productivity (10), Internet (7), Media (7), Games (11), DevTools (8), and Creative (4).

## 1.1 Core Architecture

The application follows a centralized state management pattern using React Context + useReducer, exposed through the **useOS** hook (src/hooks/useOSStore.tsx). The OS store manages window lifecycle, focus via z-index stacking, desktop icons, dock items, notifications, context menus, theme state, and Alt+Tab navigation. The **Virtual File System** (src/hooks/useFileSystem.ts) provides an ID-based hierarchical node structure with CRUD operations, trash handling, path resolution, and localStorage persistence. All app components are registered in src/apps/registry.ts and routed through src/apps/AppRouter.tsx using React.lazy() + Suspense for code splitting.

## 1.2 Tech Stack (Verified from package.json)

| Technology   | Version | Purpose                                         |
|--------------|---------|-------------------------------------------------|
| React        | 19.2.0  | Component-based UI and hook-based logic         |
| TypeScript   | 5.9.3   | Strict type safety across the OS store          |
| Vite         | 7.2.4   | Build tool with code splitting and dev server   |
| Tailwind CSS | 3.4.19  | Utility-first styling with Ubuntu design tokens |
| DOMPurify    | 3.4.7   | XSS sanitization for user-generated HTML        |
| Zod          | 4.3.5   | Runtime schema validation for persistence       |
| Lucide React | 0.562.0 | Vector iconography for apps and UI              |
| Vitest       | 4.1.7   | Unit testing framework                          |

## 1.3 Security Architecture

A comprehensive security audit and remediation was completed on 2026-05-31. The remediation replaced all eval() and new Function() calls with a hardened shunting-yard math parser (safeEval.ts), wrapped all dangerouslySetInnerHTML instances in DOMPurify-based sanitization (sanitizeHtml.ts), and added zod schema validation for all OS-level localStorage reads (storageValidation.ts). A convenience utility (safeJsonParse.ts) was introduced for ad-hoc app-specific localStorage validation. The audit found these core security fixes to be properly implemented and confirmed in the source code.

## 2. Phase 1: Document-by-Document Deep Extraction

---

### 2.1 AGENTS.md (AI Agent Briefing)

This is the primary technical reference for AI agents. It documents the window manager state machine (z-index stacking with 2147483647 cap, state transitions for minimize/maximize/restore/close), the safeEval mandatory rule, the sanitizeHtml mandatory rule, the localStorage validation mandatory rule, and the Virtual File System architecture (ID-based nodes, versioned key ubuntuos\_filesystem\_v2, legacy migration support). It lists 4 outstanding issues: (1) ~17 apps with unvalidated JSON.parse, (2) VFS localStorage 5MB limit, (3) Accessibility gaps in games and media apps, (4) No CI/CD pipeline. It also documents performance patterns including React.lazy + Suspense code splitting and the shared DynamicIcon component.

### 2.2 CLAUDE.md (Coding Standards)

Defines implementation standards for React 19 + TypeScript with strict mode. Key rules: no any type, use useOS hook for global state, build hygiene with noUnusedLocals and noUnusedParameters. Lists forbidden patterns: eval(), raw dangerouslySetInnerHTML, unvalidated localStorage. Recommends named imports from lucide-react (not import \* as Icons). Documents the safeEval, sanitizeHtml, and safeJsonParse utilities. Recommends migrating VFS to IndexedDB, adding CI/CD, splitting osReducer, and fixing ~17 remaining raw JSON.parse apps.

### 2.3 GEMINI.md (Project Context)

Provides a concise project overview with the same security rules as AGENTS.md and CLAUDE.md. Lists all technologies with versions. Specifies development conventions: strict typing, functional components with memo, hooks-first business logic, and PascalCase/camelCase naming. The security section is nearly identical to CLAUDE.md, reinforcing the non-negotiable nature of the safeEval, sanitizeHtml, and zod validation rules.

### 2.4 README.md (User-Facing Documentation)

The most detailed public-facing document. Lists exact dependency versions in a tech stack table. Claims 41 tests in the Vitest suite, 54 functional applications, and documents the security remediation history. Includes a features table with app category counts matching the registry. Lists 6 known issues and recommendations. References REMEDIATION.md for the full audit report (not provided in the codebase bundle). Claims the test suite has "41 tests" and documents build commands.

## 3. Phase 2: Cross-Document Reconciliation

The following table reconciles key claims across all four documentation files. Verdicts indicate whether documents agree (Consistent), disagree on facts (Discrepant), or one document omits a topic covered by others (Gap).

| Topic                          | Verdict    | Details                                                                                                         |
|--------------------------------|------------|-----------------------------------------------------------------------------------------------------------------|
| App count = 54                 | Consistent | All four documents state 54 apps. Registry.tsx confirms 54 entries.                                             |
| React 19                       | Consistent | All docs agree. package.json: react 19.2.0.                                                                     |
| TypeScript 5.9                 | Consistent | All docs agree. package.json: typescript ~5.9.3.                                                                |
| Vite 7.2                       | Consistent | GEMINI.md and README agree. package.json: vite ^7.2.4.                                                          |
| DOMPurify version              | Gap        | README says 3.4.7. package.json: dompurify ^3.4.7. Other docs omit version.                                     |
| Zod version                    | Gap        | README says 4.3.5. package.json: zod ^4.3.5. Other docs omit version.                                           |
| Lucide version                 | Discrepant | README says 0.562.0 exact. package.json: ^0.562.0 (range). Minor.                                               |
| osReducer line count           | Discrepant | AGENTS.md: "499-line osReducer". CLAUDE.md: "499-line". README: "500-line". Actual: ~350 lines of reducer code. |
| Test count                     | Gap        | Only README claims "41 tests". Other docs do not state a number.                                                |
| Dev server port                | Gap        | Only GEMINI.md says "http://localhost:3000". vite.config.ts confirms port: 3000.                                |
| eval/new Function removed      | Consistent | All docs state these are eliminated. Source code confirms.                                                      |
| safeEval mandatory             | Consistent | All docs mandate safeEval for math. Code confirms usage in Spreadsheet + Terminal.                              |
| sanitizeHtml mandatory         | Consistent | All docs mandate sanitization. 4 of 5 dangerouslySetInnerHTML instances sanitized.                              |
| 17 apps unvalidated JSON.parse | Consistent | AGENTS.md and CLAUDE.md list same 17 apps. Code confirms 21 raw JSON.parse calls in those apps.                 |
| localStorage key               | Consistent | All docs say ubuntuos_filesystem_v2. Code confirms.                                                             |
| Vitest version                 | Gap        | README says "4.x". package.json: vitest ^4.1.7. Other docs omit version.                                        |

### 3.1 Key Discrepancies

**osReducer line count:** AGENTS.md and CLAUDE.md claim "499-line osReducer" while README says "500-line". The actual reducer function in the provided code is approximately 350 lines (lines 31321-31669 of the bundle). This discrepancy suggests the documentation was written before a refactoring that reduced the reducer size, and the line count claims were not updated. This is a documentation accuracy issue, not a code bug.

**Test count:** README.md claims "41 tests" but this is unverifiable without running the full test suite. The provided test files contain approximately 30 visible test cases across safeEval.test.ts (24 cases), safeJsonParse.test.ts (3 cases), safeJsonParse-integration.test.ts (3 cases), osReducer-zindex.test.tsx (2 cases), osReducer.test.ts (1 placeholder),

NotImplemented.test.tsx (unknown count, file truncated), and ContextMenu-actions.test.tsx (unknown count, file truncated). The "41 tests" claim cannot be fully verified from the provided code bundle alone.

## 4. Phase 3: Source Code Validation

Each material claim from the documentation was traced to the corresponding source code and verified. Outcomes: Confirmed (code supports the claim), Discrepant (code contradicts the claim), or Unverifiable (required source not available in the bundle).

| Claim                                                    | Verdict      | Evidence                                                                                                                                |
|----------------------------------------------------------|--------------|-----------------------------------------------------------------------------------------------------------------------------------------|
| 54 apps in registry                                      | Confirmed    | registry.ts contains exactly 54 AppDefinition entries with correct category counts.                                                     |
| React.lazy + Suspense in AppRouter                       | Confirmed    | AppRouter.tsx uses React.lazy() for all 55 app components; NotImplemented is the only eagerly imported fallback.                        |
| Z-index cap at 2147483647                                | Confirmed    | OPEN_WINDOW, FOCUS_WINDOW, and END_ALT_TAB all use Math.min(nextZIndex + 1, 2147483647).                                                |
| eval() eliminated from Spreadsheet                       | Confirmed    | Spreadsheet.tsx imports and uses safeEval from @/utils/safeEval (line 21216). No eval() found.                                          |
| eval() eliminated from Terminal                          | Confirmed    | Terminal.tsx imports and uses safeEval from @/utils/safeEval (line 26020). No eval() found.                                             |
| DOMPurify sanitization for all dangerouslySetInnerHTML   | Discrepant   | 4 of 5 instances sanitized. chart.tsx (line 7983) uses dangerouslySetInnerHTML without sanitizeHtml.                                    |
| safeJsonParse used in PasswordManager, Contacts, Browser | Confirmed    | All three import and use safeJsonParse with zod schemas for localStorage reads.                                                         |
| storageValidation for desktop icons + VFS                | Confirmed    | useOSStore.tsx uses validateDesktopIcons(); useFileSystem.ts uses validateFileSystem().                                                 |
| DynamicIcon shared component with memo()                 | Confirmed    | src/components/DynamicIcon.tsx exists, uses memo(), and is imported by 7+ components.                                                   |
| osReducer exported for testing                           | Confirmed    | osReducer is exported as a named export from useOSStore.tsx.                                                                            |
| Side effects extracted from reducer                      | Confirmed    | Desktop icon localStorage writes moved to useEffect in OSProvider. Reducer is pure.                                                     |
| NotImplemented.tsx has lucide-react import               | Discrepant   | NotImplemented.tsx still has "import * as Icons from lucide-react" (line 1910). Documentation says bug was fixed.                       |
| Named imports only for lucide-react                      | Discrepant   | WindowFrame.tsx (line 8907) and NotImplemented.tsx (line 1910) still use wildcard imports. DynamicIcon.tsx is the authorized exception. |
| VFS key ubuntuos_filesystem_v2                           | Confirmed    | storageValidation.ts uses FILESYSTEM_KEY = "ubuntuos_filesystem_v2" and LEGACY_FILESYSTEM_KEY for migration.                            |
| No CI/CD pipeline                                        | Unverifiable | No CI/CD config files provided in bundle. Cannot confirm or deny.                                                                       |
| Test count = 41                                          | Unverifiable | Cannot run test suite from bundle. Visible test cases total approximately 30+, but some test files are truncated.                       |
| Bundle reduced from ~1MB to ~360KB                       | Unverifiable | Cannot run build from bundle. React.lazy pattern is confirmed in code, which supports the claim.                                        |

### 4.1 Source Code Gap Identification (Independent of Documentation)

The following issues were found by scanning source code independently, without reference to documentation claims. These represent bugs, dead code, missing patterns, or architectural concerns discovered during the audit.

| Issue                                            | Location                                    | Detail                                                                                                                |
|--------------------------------------------------|---------------------------------------------|-----------------------------------------------------------------------------------------------------------------------|
| WindowFrame.tsx uses wildcard lucide import      | src/components/WindowFrame.tsx line 8907    | Imports entire ~587KB library unnecessarily; component also imports DynamicIcon.                                      |
| NotImplemented.tsx dead wildcard import          | src/components/NotImplemented.tsx line 1910 | Imports * as Icons but only uses Icons.HelpCircle and Icons.Hammer; DynamicIcon already imported.                     |
| Desktop.tsx commented-out import                 | src/components/Desktop.tsx line 1252        | Commented "import * as Icons" line remains; should be removed for cleanliness.                                        |
| osReducer.test.ts is a placeholder               | src/hooks/__tests__/osReducer.test.ts       | Contains only "expect(true).toBe(true)" and comments saying osReducer is not testable. But osReducer IS now exported. |
| sanitizeMarkdownHtml is local to MarkdownPreview | src/apps/MarkdownPreview.tsx line 11743     | Not exported from @/utils/sanitizeHtml as documentation implies. It is a local function in MarkdownPreview.tsx.       |
| CASCADE_WINDOWS does not cap z-index             | src/hooks/useOSSStore.tsx line 31637        | CASCADE_WINDOWS increments z without the Math.min cap. Potential overflow in long sessions.                           |
| MINIMIZE_ALL does not save prevPosition/prevSize | src/hooks/useOSSStore.tsx line 31653        | MINIMIZE_ALL sets state to minimized but does not capture prevPosition/prevSize, making restore impossible.           |
| GlobalErrorBoundary not used in WindowManager    | src/components/WindowManager.tsx            | GlobalErrorBoundary exists but is not imported or used in WindowManager or AppRouter. Apps can crash the shell.       |



# 5. Phase 4: Multi-Dimensional Critical Audit

---

## 5.1 Security Audit

The security audit traced all user input to render pipelines and verified the presence of stated mitigations. The core security architecture is sound: `eval()` and `new Function()` have been completely eliminated, DOMPurify sanitization is applied to 4 of 5 `dangerouslySetInnerHTML` instances, and OS-level `localStorage` reads are validated with zod schemas. However, several gaps remain.

### 5.1.1 Unvalidated `localStorage` Reads (High Severity)

Twenty-one raw `JSON.parse` calls across 17 application files read from `localStorage` without zod schema validation. This violates the mandatory rule stated in all documentation files. If `localStorage` data is corrupted (by user editing DevTools, browser extensions, or disk errors), the parsed objects will have an unknown shape at runtime, potentially causing crashes, undefined behavior, or rendering of unexpected content. The apps affected are: Clock (2 calls), Todo (2), ColorPalette (1), ColorPicker (2), TextEditor (1), Calendar (1), Reminders (1), Memory (1), Spreadsheet (1), Chat (1), RssReader (1), Settings (1), Notes (2), ArchiveManager (1), ScreenRecorder (1), Calculator (1), and VoiceRecorder (1). The PasswordManager, Contacts, and Browser apps already use the correct `safeJsonParse` pattern and serve as reference implementations.

### 5.1.2 Unsanitized `dangerouslySetInnerHTML` in `chart.tsx` (Medium Severity)

The `chart.tsx` UI component (line 7983) uses `dangerouslySetInnerHTML` to inject dynamically generated CSS from `ChartConfig` color values. While the content is built from configuration objects rather than direct user input, this still bypasses the mandatory sanitization policy. If a chart color value were ever sourced from user input (e.g., custom theme colors), this would become an XSS vector. The fix is straightforward: wrap the generated CSS string in `sanitizeHtml()` or add a code comment explicitly documenting the exemption and its safety justification.

### 5.1.3 Password Manager Security Note (Informational)

The PasswordManager stores passwords in `localStorage` using `safeJsonParse` with zod validation. While the persistence layer is validated, the passwords themselves are stored as plaintext strings in `localStorage`. This is a design limitation rather than a bug (any web-accessible JavaScript can read `localStorage`), but it should be documented as a known security constraint. In a production environment, passwords should be encrypted before storage or handled by a dedicated secrets API.

## 5.2 Bug and Reliability Audit

### 5.2.1 MINIMIZE\_ALL Does Not Save Window Positions (Medium Severity)

The MINIMIZE\_ALL reducer case (useOSStore.tsx line 31653) sets all windows to minimized state but does not capture prevPosition and prevSize on each window. This means that after a "Minimize All" action (Super+D), restoring individual windows will fall back to their current position/size rather than their pre-minimize positions. In contrast, the individual MINIMIZE\_WINDOW action correctly saves prevPosition and prevSize. This inconsistency creates a user experience regression where the restore behavior differs depending on whether windows were minimized individually or via "Minimize All".

### 5.2.2 CASCADE\_WINDOWS Missing Z-Index Cap (Medium Severity)

The CASCADE\_WINDOWS action (useOSStore.tsx line 31637) increments the z-index counter in a loop without applying the  $\text{Math.min}(\text{state.nextZIndex} + 1, 2147483647)$  cap that is present in OPEN\_WINDOW, FOCUS\_WINDOW, and END\_ALT\_TAB. If a user repeatedly triggers CASCADE\_WINDOWS in a long session, the z-index could exceed the CSS maximum, causing window focus to become erratic. The documentation specifically notes this as a fixed issue with "confirm all three locations have the cap," but it missed the CASCADE\_WINDOWS case.

### 5.2.3 GlobalErrorBoundary Not Wired Into Component Tree (Medium Severity)

The GlobalErrorBoundary component (src/components/GlobalErrorBoundary.tsx) is implemented and documented as a wrapper that prevents individual app crashes from taking down the entire desktop shell. However, it is not imported or used in the WindowManager.tsx or AppRouter.tsx component tree. This means a thrown error in any app component will propagate up to the React root and potentially crash the entire UbuntuOS shell, defeating the purpose of the error boundary. The component should wrap each AppRouter invocation inside WindowFrame.

### 5.2.4 Stale osReducer.test.ts Placeholder (Low Severity)

The file src/hooks/\_\_tests\_\_/osReducer.test.ts contains a comment stating "osReducer is not exported from useOSStore.tsx" and a single placeholder test "expect(true).toBe(true)". However, osReducer IS now exported (line 31321: "export function osReducer"). The test file was apparently written before the export was added and never updated. This means the osReducer has only 2 z-index-specific tests in osReducer-zindex.test.tsx and no tests for its other 25+ action types (MINIMIZE\_WINDOW, RESTORE\_WINDOW, ADD\_NOTIFICATION, etc.).

## 5.3 Architecture and Design Audit

### 5.3.1 Monolithic Reducer (Medium Severity)

The osReducer handles window management, dock state, notifications, context menus, desktop icons, theme, and Alt+Tab navigation in a single function. All documentation files acknowledge this as a known issue and recommend splitting into domain-specific reducers. The current structure makes testing individual domains difficult, increases cognitive load

for developers, and creates merge conflict risks. The recommended split is: windowReducer, dockReducer, notificationReducer, contextMenuReducer, iconReducer, themeReducer, and altTabReducer.

### 5.3.2 Lucide React Wildcard Import Bundle Bloat (Medium Severity)

Two components (WindowFrame.tsx and NotImplemented.tsx) import the entire lucide-react library using "import \* as Icons from lucide-react", which adds approximately 587 KB to the bundle. DynamicIcon.tsx is the single authorized wildcard import because it needs to resolve icons by string name at runtime. WindowFrame.tsx already imports DynamicIcon, so the wildcard import is redundant. NotImplemented.tsx uses Icons.HelpCircle and Icons.Hammer, which could be replaced with named imports. Despite the explicit documentation rule against wildcard imports, these violations persist.

### 5.3.3 sanitizeMarkdownHtml Not Exported from Utils (Low Severity)

All three AI agent documents (AGENTS.md, CLAUDE.md, GEMINI.md) reference sanitizeMarkdownHtml() as a function available from the @/utils/sanitizeHtml module. However, the actual implementation is a local function defined inside MarkdownPreview.tsx (line 11743), not exported from the utils module. This means any new app that needs markdown sanitization cannot import it as documented and would need to duplicate the logic or import it from the MarkdownPreview app file directly, which violates the project structure conventions.

## 5.4 Testing Audit

The test infrastructure is built on Vitest with jsdom environment and @testing-library/jest-dom matchers. The provided test files cover safeEval (24 test cases), safeJsonParse (3 unit + 3 integration tests), and osReducer z-index cap (2 tests). However, significant gaps exist: no component-level tests for WindowFrame, Desktop, Dock, or AppRouter (all identified as high-value targets in CLAUDE.md); the osReducer.test.ts file is a placeholder; and the NotImplemented.test.tsx and ContextMenu-actions.test.tsx files are present but partially truncated in the bundle. The total visible test count is approximately 30-33, which is below the README claim of 41 tests (though this cannot be definitively confirmed without running the suite).

## 5.5 Documentation Accuracy Audit

| Claim                                        | Verdict    | Detail                                                                          |
|----------------------------------------------|------------|---------------------------------------------------------------------------------|
| osReducer "499-line" / "500-line"            | Discrepant | Actual reducer is approximately 350 lines. Documentation counts are stale.      |
| NotImplemented.tsx bug "fixed"               | Discrepant | Wildcard import still present. Documentation claims fix is applied.             |
| sanitizeMarkdownHtml in @/utils/sanitizeHtml | Discrepant | Function is local to MarkdownPreview.tsx, not in utils module.                  |
| Z-index cap "in all three locations"         | Discrepant | CASCADE_WINDOWS also increments z-index without cap. Four locations, not three. |

| Claim                                                    | Verdict   | Detail                                                    |
|----------------------------------------------------------|-----------|-----------------------------------------------------------|
| No eval() / new Function() in codebase                   | Confirmed | Thorough search found zero instances in application code. |
| 54 apps in registry                                      | Confirmed | Exact count and category distribution verified.           |
| safeEval used in Spreadsheet + Terminal                  | Confirmed | Both import and use safeEval. No raw eval found.          |
| safeJsonParse used in PasswordManager, Contacts, Browser | Confirmed | All three use safeJsonParse with zod schemas.             |
| React.lazy + Suspense code splitting                     | Confirmed | All apps use lazy() in AppRouter with Suspense fallback.  |
| Side effects extracted from reducer                      | Confirmed | localStorage writes in useEffect; reducer is pure.        |

## 6. Phase 5: Consolidated Severity-Ranked Findings

### 6.1 Critical Issues

No critical issues were identified. There are no active, exploitable security vulnerabilities in the codebase. The core security architecture (safeEval replacing eval, DOMPurify sanitization, zod validation for OS-level persistence) is properly implemented and confirmed through source code verification.

### 6.2 High-Severity Issues

| # | Severity | Category    | Finding                                                                                                                                                                                                                                                                                               | Location                                                                                                                                                                                                                                                      | Impact                                                                                                                                                          | Phase |
|---|----------|-------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------|-------|
| 1 | High     | Security    | 21 raw JSON.parse calls across 17 apps read localStorage without zod validation. Corrupted or maliciously modified localStorage data can cause crashes, undefined behavior, or unexpected content rendering. This violates the mandatory validation rule stated in all documentation files.           | Clock.tsx, Todo.tsx, ColorPalette.tsx, ColorPicker.tsx, TextEditor.tsx, Calendar.tsx, Reminders.tsx, Memory.tsx, Spreadsheet.tsx, Chat.tsx, RssReader.tsx, Settings.tsx, Notes.tsx, ArchiveManager.tsx, ScreenRecorder.tsx, Calculator.tsx, VoiceRecorder.tsx | Runtime crashes from malformed localStorage data; potential stored-XSS if parsed content reaches dangerouslySetInnerHTML; violates documented security policy   | P3+P4 |
| 2 | High     | Performance | WindowFrame.tsx and NotImplemented.tsx import the entire lucide-react library (~587 KB) via wildcard imports, directly contradicting the documented rule "Do not use import * as Icons from lucide-react". These imports add unnecessary bundle weight and negate part of the code-splitting savings. | src/components/WindowFrame.tsx line 8907; src/components/NotImplemented.tsx line 1910                                                                                                                                                                         | ~587 KB unnecessary bundle bloat per wildcard import; violates documented coding convention; increases initial load time for chunks containing these components | P3+P4 |

### 6.3 Medium-Severity Issues

| # | Severity | Category | Finding                                                                                                                                                             | Location                              | Impact                                                                          | Phase |
|---|----------|----------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------|---------------------------------------------------------------------------------|-------|
| 1 | Medium   | Security | dangerouslySetInnerHTML in chart.tsx (UI component) injects dynamically generated CSS without sanitizeHtml() wrapping, violating the mandatory sanitization policy. | src/components/ui/chart.tsx line 7983 | Policy violation; potential XSS if chart color values ever come from user input | P4    |

| # | Severity | Category      | Finding                                                                                                                                                                     | Location                                                                 | Impact                                                                                        | Phase |
|---|----------|---------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------|-------|
| 2 | Medium   | Reliability   | MINIMIZE_ALL reducer does not save prevPosition/prevSize, unlike individual MINIMIZE_WINDOW. Restoring windows after "Minimize All" loses original positions.               | src/hooks/useOSStore.tsx line 31653-31664                                | UX regression: window restore behavior inconsistent depending on minimize method              | P4    |
| 3 | Medium   | Reliability   | CASCADE_WINDOWS increments z-index without the Math.min cap present in OPEN_WINDOW, FOCUS_WINDOW, and END_ALT_TAB. Can overflow CSS max z-index in long sessions.           | src/hooks/useOSStore.tsx line 31637-31651                                | Erratic window focus in long sessions after repeated cascade operations                       | P4    |
| 4 | Medium   | Reliability   | GlobalErrorBoundary component exists but is not wired into the component tree. App errors can propagate to the React root and crash the entire desktop shell.               | src/components/GlobalErrorBoundary.tsx; src/components/WindowManager.tsx | Single app crash can take down the entire UbuntuOS shell; defeats error boundary purpose      | P4    |
| 5 | Medium   | Architecture  | Monolithic osReducer handles 25+ action types across 7 domains. Difficult to test, maintain, and reason about. All documentation acknowledges this issue.                   | src/hooks/useOSStore.tsx                                                 | High cognitive load for developers; merge conflict risk; difficult to test individual domains | P2+P4 |
| 6 | Medium   | Documentation | Documentation claims NotImplemented.tsx lucide import bug is "fixed", but wildcard import still present at line 1910. Icons.HelpCircle and Icons.Hammer are still used.     | src/components/NotImplemented.tsx line 1910; AGENTS.md, CLAUDE.md        | Documentation-code mismatch; developers may trust incorrect documentation                     | P3    |
| 7 | Medium   | Documentation | sanitizeMarkdownHtml is documented as available from @/utils/sanitizeHtml but is actually a local function in MarkdownPreview.tsx. New apps cannot import it as documented. | src/apps/MarkdownPreview.tsx line 11743; AGENTS.md, CLAUDE.md, GEMINI.md | Documentation-code mismatch; developers will encounter import errors following the docs       | P3    |
| 8 | Medium   | Documentation | Z-index cap documented as "present in all three locations" (OPEN_WINDOW, FOCUS_WINDOW, END_ALT_TAB) but CASCADE_WINDOWS also increments z-index without the cap.            | src/hooks/useOSStore.tsx line 31637; AGENTS.md troubleshooting section   | Incomplete fix; documentation understates the scope of the z-index overflow risk              | P3+P4 |

## 6.4 Low-Severity Issues

| # | Severity | Category      | Finding                                                                                                                                                   | Location                                                     | Impact                                                                                        | Phase |
|---|----------|---------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------|-----------------------------------------------------------------------------------------------|-------|
| 1 | Low      | Testing       | osReducer.test.ts is a placeholder with a single "expect(true).toBe(true)" test. The osReducer is now exported but the test file was never updated.       | src/hooks/__tests__/osReducer.test.ts                        | 25+ action types in osReducer have no test coverage                                           | P4    |
| 2 | Low      | Code Quality  | Desktop.tsx retains a commented-out "import * as Icons from lucide-react" line that should be removed for cleanliness.                                    | src/components/Desktop.tsx line 1252                         | Dead commented code; minor hygiene issue                                                      | P3    |
| 3 | Low      | Documentation | osReducer line count claimed as "499-line" (AGENTS.md, CLAUDE.md) or "500-line" (README) but actual code is approximately 350 lines. Stale documentation. | AGENTS.md, CLAUDE.md, README.md                              | Minor documentation inaccuracy; no functional impact                                          | P2    |
| 4 | Low      | Testing       | No component-level tests for WindowFrame, Desktop, Dock, or AppRouter despite being identified as high-value test targets in CLAUDE.md.                   | Missing: src/components/__tests__/WindowFrame.test.tsx, etc. | Core UI components have no test coverage; regressions may go undetected                       | P4    |
| 5 | Low      | Security      | PasswordManager stores passwords as plaintext in localStorage. Not a bug, but a design limitation that should be documented.                              | src/apps/PasswordManager.tsx                                 | Passwords readable by any JS code in the same origin; acceptable for demo, not for production | P4    |

## 6.5 Informational Observations (Confirmed Positives)

| # | Severity      | Category | Finding                                                                                                                                                               | Location                                                                 | Impact                                                                    | Phase |
|---|---------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------|---------------------------------------------------------------------------|-------|
| 1 | Informational | Security | eval() and new Function() completely eliminated from all application code. safeEval shunting-yard parser is properly implemented with character whitelist validation. | src/utils/safeEval.ts; Spreadsheet.tsx; Terminal.tsx                     | No arbitrary code execution vectors in math evaluation paths              | P3    |
| 2 | Informational | Security | DOMPurify sanitization correctly applied to 4 of 5 dangerouslySetInnerHTML instances: MarkdownPreview, CodeEditor, Notes, and RegexTester.                            | src/apps/MarkdownPreview.tsx, CodeEditor.tsx, Notes.tsx, RegexTester.tsx | Stored XSS vectors mitigated for markdown, code, notes, and regex content | P3    |

| # | Severity      | Category     | Finding                                                                                                                                                            | Location                                    | Impact                                                         | Phase |
|---|---------------|--------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------|----------------------------------------------------------------|-------|
| 3 | Informational | Architecture | React.lazy + Suspense code splitting properly implemented in AppRouter with AppSkeleton fallback. NotImplemented is correctly the only eagerly imported component. | src/apps/AppRouter.tsx                      | Initial bundle significantly reduced; apps loaded on demand    | P3    |
| 4 | Informational | Architecture | Shared DynamicIcon component with memo() eliminates icon rendering duplication across 7+ components (Dock, WindowFrame, Desktop, AppLauncher, etc.).               | src/components/DynamicIcon.tsx              | Consistent icon rendering with performance optimization        | P3    |
| 5 | Informational | Architecture | Reducer purity maintained: localStorage side effects extracted to useEffect in OSProvider. Reducer is deterministic and testable.                                  | src/hooks/useOSSStore.tsx lines 31684-31686 | Clean separation of concerns; reducer behavior is reproducible | P3    |
| 6 | Informational | Validation   | safeEval test suite has 24 comprehensive cases covering basic arithmetic, decimals, parentheses, exponentiation, whitespace, edge cases, and injection rejection.  | src/utils/__tests__/safeEval.test.ts        | Security-critical code has thorough test coverage              | P4    |



## 7. Improvement Recommendations

The following recommendations are prioritized by impact and urgency. Each is directly traceable to a specific finding from this audit.

| Priority | Recommendation                                                                                                                                                                                                                                                                                                            | Traceability             |
|----------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------|
| P0       | Migrate 17 apps from <code>raw JSON.parse</code> to <code>safeJsonParse</code> with zod schemas. Follow the <code>PasswordManager/Contacts/Browser</code> reference pattern. This eliminates the largest remaining security/reliability gap.                                                                              | High #1                  |
| P1       | Remove wildcard <code>lucide-react</code> imports from <code>WindowFrame.tsx</code> and <code>NotImplemented.tsx</code> . Replace with named imports ( <code>HelpCircle</code> , <code>Hammer</code> ) or use the existing <code>DynamicIcon</code> component. Saves ~587 KB per import.                                  | High #2                  |
| P1       | Wire <code>GlobalErrorBoundary</code> into the <code>WindowManager</code> component tree, wrapping each <code>AppRouter</code> invocation inside <code>WindowFrame</code> . This prevents single app crashes from taking down the desktop.                                                                                | Medium #4                |
| P2       | Add <code>Math.min</code> cap to <code>CASCADE_WINDOWS</code> z-index increment. The fix is a one-line change mirroring the pattern in <code>OPEN_WINDOW/FOCUS_WINDOW/END_ALT_TAB</code> .                                                                                                                                | Medium #3                |
| P2       | Fix <code>MINIMIZE_ALL</code> to save <code>prevPosition</code> and <code>prevSize</code> for each window before minimizing, consistent with individual <code>MINIMIZE_WINDOW</code> behavior.                                                                                                                            | Medium #2                |
| P2       | Export <code>sanitizeMarkdownHtml</code> from <code>@/utils/sanitizeHtml</code> and update <code>MarkdownPreview.tsx</code> to import from the shared module. This aligns code with documentation.                                                                                                                        | Medium #7                |
| P2       | Wrap <code>chart.tsx</code> <code>dangerouslySetInnerHTML</code> content in <code>sanitizeHtml()</code> or add an explicit exemption comment documenting why sanitization is skipped for CSS-only injection.                                                                                                              | Medium #1                |
| P3       | Update <code>osReducer.test.ts</code> to test the now-exported <code>osReducer</code> function. Add tests for <code>MINIMIZE_WINDOW</code> , <code>RESTORE_WINDOW</code> , <code>ADD_NOTIFICATION</code> , and other action types.                                                                                        | Low #1                   |
| P3       | Split <code>osReducer</code> into domain-specific reducers ( <code>windowReducer</code> , <code>dockReducer</code> , <code>notificationReducer</code> , <code>contextMenuReducer</code> , <code>iconReducer</code> , <code>themeReducer</code> , <code>altTabReducer</code> ) for better testability and maintainability. | Medium #5                |
| P3       | Update documentation: (a) correct <code>osReducer</code> line count, (b) mark <code>NotImplemented</code> import fix as incomplete, (c) correct z-index cap scope to include <code>CASCADE_WINDOWS</code> , (d) correct <code>sanitizeMarkdownHtml</code> location.                                                       | Medium #6, #8;<br>Low #3 |
| P4       | Remove commented-out import line from <code>Desktop.tsx</code> . Add component-level tests for <code>WindowFrame</code> , <code>Desktop</code> , and <code>Dock</code> . Document <code>PasswordManager</code> plaintext storage limitation.                                                                              | Low #2, #4, #5           |

**Audit Methodology:** This report was produced by a five-phase audit process: (1) document-by-document deep extraction from `AGENTS.md`, `CLAUDE.md`, `GEMINI.md`, and `README.md`; (2) cross-document reconciliation to identify consistencies, discrepancies, and gaps; (3) source code validation of every material claim against the actual codebase; (4) independent multi-dimensional audit across security, reliability, architecture, testing, and documentation accuracy dimensions; and (5) consolidation into severity-ranked findings with evidence traceability. All findings are grounded in specific lines of code, configuration values, or documentation statements from the provided codebase bundle.